Patient Data Handling and Consent Standard

MERIDIAN HEALTH PARTNERS
OPERATIONS POLICY MANUAL
STANDARD: CLINICAL AND ADMINISTRATIVE DATA HANDLING
POLICY REF: MHP-SOP-2024-042
EFFECTIVE DATE: 15 JANUARY 2025
APPLICABILITY: ALL 14 MERIDIAN HEALTH PARTNERS SITES

1. PURPOSE AND SCOPE

1.1 This Standard defines the mandatory operational requirements for the creation, capture, access, retention, disclosure, and protection of all patient health information (PHI) and personally identifiable information (PII) across all fourteen Meridian Health Partners (MHP) outpatient facilities.

1.2 This Standard enforces compliance with both the Digital Personal Data Protection (DPDP) Act 2023 and the Health Insurance Portability and Accountability Act (HIPAA), alongside applicable state and municipal regulations. Where jurisdictional standards diverge, the more restrictive standard shall apply.

1.3 Compliance with this Standard is mandatory for all full-time, part-time, and contract personnel, including clinical staff, administrative staff, IT support, and third-party vendors.

2. CONSENT CAPTURE AND MANAGEMENT

2.1 No patient data shall be collected, processed, or disclosed without explicit, affirmative, and informed consent, except in emergency medical circumstances as defined in Section 2.5.

2.2 Consent Capture Mechanism:
* (a) Consent shall be captured electronically via the MHP Patient Portal or via signed physical forms at site reception desks.
* (b) The consent notice must be presented in clear, plain language in English and the primary local language of the respective clinic site.
* (c) The consent artifact must itemize specific processing purposes, including clinical treatment, billing, quality assurance, and-where separately opted-in—secondary clinical research.

2.3 Withdrawal of Consent:
* (a) Patients retain the right to withdraw consent at any time.
* (b) Withdrawal requests must be submitted via the MHP Patient Portal or in writing to the Site Privacy Officer.
* (c) Upon receipt, MHP shall cease processing the affected data within forty-eight (48) hours, except where retention is required by clinical necessity or statutory obligation under Section 4.

2.4 Minor Consent: For patients under the age of eighteen (18), consent must be captured from a designated parent or legal guardian, except for reproductive health, mental health, or substance abuse services where state statute or clinical discretion permits minor self-consent.

2.5 Named Exceptions: Explicit consent is not required prior to data collection in the following instances:
* (a) Medical emergencies where the patient is incapacitated and immediate intervention is required to prevent death or serious bodily harm.
* (b) Mandatory public health reporting of infectious diseases directed by municipal or national health authorities.
* (c) Validated judicial subpoenas or court orders executed in accordance with MHP Legal Counsel review.

3. MINIMUM NECESSARY ACCESS

3.1 Access to patient data shall be restricted based on the principle of least privilege, ensuring employees access only the specific data elements required to perform their assigned job functions.

3.2 Role-Based Access Control (RBAC) Tiers:
* Tier 1 (Front Desk & Scheduling): Access restricted to demographic data, insurance details, appointment history, and basic contact information. Clinical notes and diagnostic results are strictly excluded.
* Tier 2 (Billing & Revenue Cycle): Access restricted to demographic data, encounter codes, billing history, and payment details. Clinical progress notes are restricted to procedural codes required for claims substantiation.
* Tier 3 (Clinical Staff - Nurses & Medical Assistants): Access permitted to vital signs, medication history, allergy lists, and treating physician notes for active patients assigned to their specific clinic site.
* Tier 4 (Treating Physicians & Specialists): Full read/write access to complete electronic health records (EHR) for assigned patients across all fourteen MHP sites.
* Tier 5 (System Administrators): System-level technical access restricted to metadata, system logs, and encrypted backup files. Administrators are strictly prohibited from viewing clinical content unless explicitly authorized by the Chief Information Security Officer (CISO) for verified troubleshooting.

3.3 Access Audits: The IT Security Department shall run automated monthly audit logs across all fourteen sites to identify anomalous record-viewing patterns. Any access of a record outside an employee's assigned patient panel or department shall trigger an automated review by the Compliance Directorate within seventy-two (72) hours.

4. DATA RETENTION PERIODS BY RECORD TYPE

4.1 All patient records, regardless of format (electronic or physical), shall be retained in accordance with the schedule below. No records shall be destroyed prior to the expiration of the defined retention period.

Record Type	Mandatory Retention Period	Calculation Baseline
Adult Outpatient Clinical Records	7 Years	From the date of the last patient encounter.
Pediatric Outpatient Clinical Records	7 Years After Age of Majority (25 Years Total)	From the date of the patient's eighteenth (18th) birthday.
Diagnostic Imaging & Laboratory Reports	7 Years	From the date of service.
Financial, Billing, and Claims Records	6 Years	From the date of final invoice settlement or claim adjudication.
Consent Artifacts and Withdrawal Logs	7 Years	From the date of revocation or expiration of the associated clinical record.
System Access and Audit Logs	3 Years	From the date of log generation.

4.2 Destruction Protocols: Upon expiration of the retention period, physical records shall be cross-cut shredded on-site by a certified third-party destruction vendor, generating a Certificate of Destruction within thirty (30) days. Electronic records shall be permanently purged from primary and backup storage media in compliance with NIST SP 800-88 Revision 1 sanitization standards.

5. PATIENT DATA-ACCESS REQUEST (DSAR) PROCESS

5.1 Patients, or their legally authorized representatives, possess the right to access, inspect, and obtain copies of their health records maintained by MHP.

5.2 Request Submission:
* (a) Requests must be submitted via the MHP Patient Portal, via electronic mail to `privacy@meridianhp.com`, or via physical intake at any MHP site reception desk using Form MHP-DSAR-01.
* (b) The identity of the requester must be verified via government-issued photo identification prior to record release.

5.3 Response Deadline:
* (a) MHP shall fulfill all valid data-access requests within thirty (30) calendar days of initial receipt.
* (b) If a request is exceptionally complex or voluminous, MHP may invoke a single fifteen (15) calendar day extension. The requester must be notified in writing of the specific reason for the delay and the expected fulfillment date prior to the expiration of the initial thirty-day window.

5.4 Delivery and Fees:
* (a) Records shall be delivered securely via the encrypted MHP Patient Portal or on password-protected physical media (USB drive) per patient preference.
* (b) The first copy of a patient's record is provided at no charge. Subsequent requests within a twelve-month period may incur a processing fee calculated at actual cost for media and labor, not to exceed $25.00 USD or regional equivalent.

6. BREACH NOTIFICATION TIMELINE

6.1 A security incident involving unauthorized access, acquisition, use, or disclosure of unencrypted PHI/PII constitutes a data breach unless a documented risk assessment proves a low probability of data compromise.

6.2 Internal Escalation: Any MHP employee who discovers a suspected breach must report it to the CISO and Site Privacy Officer within two (2) hours of discovery.

6.3 Regulatory Notification Timelines:
* (a) HIPAA Compliance Threshold: For breaches affecting residents of applicable jurisdictions, MHP shall notify the U.S. Department of Health and Human Services (HHS), affected individuals, and prominent media outlets (if the breach affects more than 500 residents of a single state or jurisdiction) without unreasonable delay and in no case later than sixty (60) calendar days from the discovery of the breach.
* (b) DPDP Act 2023 Compliance Threshold: For breaches subject to the DPDP Act 2023, MHP shall notify the Data Protection Board of India (DPBI) and affected data principals in writing within seventy-two (72) hours of becoming aware of the security breach.

6.4 Notification Content: All breach notifications sent to regulatory authorities and affected individuals shall include:
* (a) A description of the incident, including date of occurrence and date of discovery.
* (b) The categories of personal data compromised (e.g., demographic, clinical, financial).
* (c) Mitigation steps taken by MHP to contain the breach.
* (d) Recommended protective actions for the affected individual.
* (e) Dedicated MHP contact details for inquiries.

7. GOVERNANCE AND ENFORCEMENT

7.1 The MHP Compliance Directorate shall conduct quarterly reviews of consent logs, DSAR fulfillment times, and access audit reports across all fourteen sites.

7.2 Failure to adhere to this Standard shall result in disciplinary action up to and including termination of employment, revocation of clinical privileges, and potential civil or criminal penalties under the DPDP Act 2023 and HIPAA.

END OF STANDARD